

中华人民共和国通信行业标准

YD/T ×××× -202X

大搜索中隐私保护技术要求

Technique requirements for privacy preservation in big search

202X-××-××发布

202X-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言	1
1. 范围	2
2. 规范性引用文件	2
3. 术语和定义	2
4. 大搜索中隐私保护的原则	3
5. 大搜索中隐私保护整体框架	3
6. 隐私数据分类和分级	5
7. 隐私度量检测	6
8. 数据传输过程的隐私保护	8

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是“大搜索”系列标准之一，该系列标准拟发布以下三项：

——《大搜索术语》

——《大搜索中隐私保护技术要求》

——《大搜索系统框架指南》

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件牵头起草单位：广州大学网络空间先进技术研究院、湖南星汉数智科技有限公司、鹏城实验室、国家计算机网络应急技术处理协调中心、西北工业大学。

本文件参与起草单位：中国信息通信研究院、北京百度网讯科技有限公司、湖南蚁坊软件有限公司、西安邮电大学、华信咨询设计研究院有限公司、哈尔滨工业大学（深圳）、电子科技大学广东电子信息工程研究院。

本文件主要起草人：李树栋、贾焰、韩伟红、吴晓波、王震、黄九鸣、田志宏、廖清、舒敏、周斌、李爱平、殷丽华、顾钊铨、贺敏、陈悦、李笑如、陈慧慧、张勇、宋曦、王晓斌、徐睿峰、刘洋、陈雷霆、曹厚华、母国才。

大搜索中隐私保护技术要求

1. 范围

本文件规定了在各类大搜索服务中对个人（用户）隐私信息的保护手段和保护技术的要求。
本文件适用于各类搜索服务和各类搜索系统平台的构建和监管，对用户个人隐私、用户数据安全等隐私保护技术的实现提供指导。

2. 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本(包括所有的修改单)适用于本文件。

GB/T 35273-2020	信息安全技术 个人信息安全规范
YD/T XXXX	大搜索术语

3. 术语和定义

下列术语和定义适用于本文件。

3.1

大搜索 big search

在面向泛在网络空间中的人、物体和信息，在正确理解用户意图基础上的，基于从网络空间大数据获取的知识，给出满足用户需求的智慧解答。

[来源：YD/T XXXX, 2.1]

3.2

去标识化 de-identification

通过对个人信息的技术处理，使其在不借助额外信息的情况下，无法识别个人信息主体的过程。

注：去除标识符与个人信息主体之间关联性。

[来源：YD/T XXXX, 2.15]

3.3

敏感属性 sensitive attribute

数据集中需要特别保护的属性。在潜在的重标识攻击期间，需要防止其值与任何一个个人信息主体相关联。

[来源：YD/T XXXX, 2.16]

3.4

有用性 usefulness

数据对于应用有着具体含义、具有使用意义的特性。去标识化数据应用广泛，每种应用将要求去标识化数据具有某些特性以达到应用目的，因此在去标识化后，需要保证对这些特性的保留。

[来源：YD/T XXXX, 2.17]

3.5

隐私计算 privacy computing

隐私计算是面向隐私信息全生命周期保护的计算理论和方法，是隐私信息的所有权、管理权和使用权分离时隐私度量、隐私泄漏代价、隐私保护与隐私分析复杂性的可计算模型与公理化系统。

3.6

隐私保护 privacy protecting

指在大搜索过程中对于用户的个人敏感信息、行为习惯等隐私信息的保护，以及对从泛在网络中获取的多维信息进行融合分析时的隐私信息保护问题。

3.7

隐私感知技术 privacy awareness

主要是从包含隐私的信息中构建隐私变量集合，或从变量集合中确定变量的取值或取值范围，产生隐私元数据，对隐私进行标记和编码，确定隐私变量的概率分布，从而对隐私变量中隐私度量的大小进行计算，为实施隐私保护提供支撑。

4. 大搜索中隐私保护的原则

在大搜索服务使用过程中，应遵循以下隐私保护原则：

- a) 公开性原则：对公开信息和个人用户信息的收集、处理与利用一般应保持公开，应当公开信息处理规则，明示处理的目的、方式和范围，以及信息处理者的名称或者姓名和联系方式；
- b) 限制性原则：个人信息的所有处理行为要坚持合法原则，个人信息数据库要坚持服务特定目的，在最少必须原则下收集和处理，信息的收集和利用、保存期限和销毁应受到限制；
- c) 数据质量原则：公开信息应当准确、完整和实时更新，大搜索服务商对此责无旁贷；如果无法保证公开信息的准确性和完整性，则应该具体说明可能存在的信息缺失部分及其造成的后果。
- d) 匿名使用原则：将收集的信息中涉及敏感用户的个性特征隐去，使用以群组统计的特征。
- e) 安全保护原则：对于已经收集到的个人数据，若未取得个人同意，则不得公开相应的个人数据应当采取合理的安全措施，防止数据的灭失或者未经授权的访问，避免数据的破坏、使用、修改或披露等风险。
- f) 责任明确与安全保证原则：明确并落实用户信息处理过程中的责任；采取适当的、与用户信息遭受损害的可能性和严重性相适应的管理措施与技术手段，保护用户信息安全。

5. 大搜索中隐私保护整体框架

大搜索需要先从公开的互联网、物联网等多个来源获取信息，对数据进行存储、处理，并为用户提供智能化查询、搜索服务，因此需要同时满足服务能力和数据隐私保护能力，在提供数据使用服务时，既可以满足服务质量又可以保护隐私。

随着网络空间不断扩展，互联网应用模式发生了显著的变化；数据呈现出爆炸性增长的趋势。大搜索——即“面向泛在网络空间的智慧搜索”，相比基于关键字的传统搜索引擎，在大数据时代更能满足用户的搜索需求，有着必要且迫切的发展、应用需求。

本章提出了一种大搜索中隐私保护整体框架，如图 1 所示。

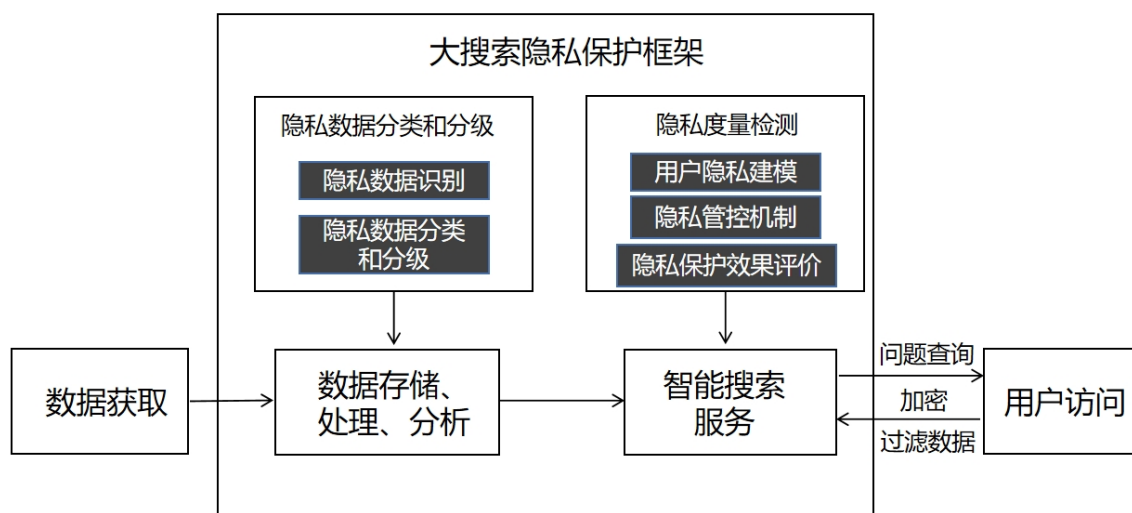


图 1 大搜索隐私保护框架

与传统的搜索引擎只从互联网获取数据不同，大搜索将从互联网、物联网、社交网络、医疗健康网络、视频监控系统、地理信息系统、智能交通管理系统以及其它网络空间应用中去采集、获取各种用户资源、信息资源、物理资源等数据，其中随时空变化的数据还会动态保持更新；在数据模式方面也更加丰富和多变，包括数字、文本、图片、视频、音频、位置、及其它们的组合等等。正是由于大搜索这种数据“泛网获取”的特点，所以在获取到的公开信息中，不可避免会存在大量个人数据和信息、涉及行业的敏感数据、涉及国家经济和政治等方面的机密信息；这些数据往往规模巨大、类型繁多、数据模式丰富多变，因而，在对获取的数据进行存储、处理和分析过程中，应对隐私数据进行多维度分类和分级。其中，涉及敏感信息的识别、去标识化、匿名化等技术，保证等级的敏感信息被区分开，有助于搜索引擎针对性的提供服务。

为了实现智能搜索服务的目的，大搜索需要在泛网数据获取的基础上，进行多元融合知识获取、并对用户意图进行感知和理解，在此基础上进行智慧解答的在线匹配。多元融合知识获取，即知识综合，要求大搜索的知识不只是来源于单个通道，而是融合了网络空间各类应用的数据，跨越了各种数据和知识的表示模式，经推演、提炼而综合出来的，从而具备更全面、更准确、更丰富的特点。知识综合突出对多源数据之间、及其不同模式数据之间可能存在关联关系进行综合分析，从而可以挖掘和发现更加新颖和更加丰富的知识。大搜索强大的关联分析能力，可以对许多重要的事和重要的人的方方面面进行关联和归纳，形成新的认知和知识；这些内容可能是个人的隐私，乃至国家的机密，因此严格的访问结果内容研判和控制，是大搜索推广使用的前提。为了对访问结果内容进行研判和控制，就要建立隐私数据交叉感知的隐私度量检测机制。其中，对于大搜索应用的用户而言，在对其隐私信息关键要素提取和自适应隐私计算的基础上进行多维用户隐私建模，实现对隐私信息的精准建模与动态度量；对搜索的结果而言，则在搜索要素抽取基础上进行关联计算与传播模型建模，实现隐私信息流向、搜索结果可管可控。

在用户访问大搜索系统时，根据用户查询的隐私程度、用户身份信息、物理特征、网络特征、访问行为等，其他时空属性，刻画用户画像，为用户准确定级，确定相应的访问权限。对于超越用户权限的查询信息，及时进行拦截，保证隐私信息在可控的范围内传播。

最后，用户访问查询和返回数据采用加密传输协议，保证数据在传输过程中不被窃取泄露。

6. 隐私数据分类和分级

6.1 概述

对于公开获取的互联网、物联网源数据，在处理过程中，应该充分考虑源数据中包含的各类敏感信息，包括大量个人数据信息、企业各类机构敏感数据、国家经济和政治方面敏感信息等，保证信息分类和分级有序，处理和查询过程可控。

6.2 隐私数据识别

网络空间数据具有多元、异构、海量等特点，针对大量复杂的源数据，需要对数据进行精准匹配、快速标记、准确识别。通过准确的隐私识别，获取数据中的敏感信息，认定是否需要删除或者分级。且对于不同数据来源的信息，需要考虑非显性的可被关联分析获取的敏感信息，对数据进行充分的挖掘。

6.3 隐私数据分类和分级

根据敏感信息的类别、时空属性、出现频率、出现范围等特征，对其进行特征建模，利用规则匹配、神经网络等方法，对其进行分类和分级，保证敏感信息与一般信息、不同类别、不同机密等级的敏感信息都能有效、准确的区分与利用。

从业务角度看，分类是企业、组织的数据按照企业数据资产管理形式，在明确敏感信息的业务范畴基础上，对信息进行划分，分类的粒度可以根据具体的业务而有不同。分级则是从数据安全、隐私保护和合规的角度，将数据的敏感等级划分为不同的几个级别，敏感等级不同的数据对内使用时受到的保护策略不同，对外共享开放的程度也不同。

一套完整的数据分类分级系统应该有如下的特点：

a) 主观判定与客观判断的支持

主观判定与客观判断主要是针对数据的敏感性（机密性）。组织内部数据分级判断常分为客观数据及主观数据，客观数据可直接辨别敏感性（如电话、身份证等），而有些数据则需要进行主观判定。

b) 具有敏感数据发现能力

敏感数据发现是数据分类分级的基础，也是客观判断的前期条件，如对电话、身份证号码、社保卡号、银行账号等多种数据进行判断，及时发现组织内部敏感数据。

c) 现有安全环境的系统映射能力

数据分类分级要考虑数据多种特性，其中包括数据安全可靠性的问题，如果组织内部具有高强度的安全可靠环境，那数据分级价值则会有限，如果环境中安全防护能力有限，则需考虑如何利用现有设备（或部分新购设备）有针对性的加深数据防护粒度，从而减轻资金、人员、运维精力等综合投入成本，在此环境下数据分类分级则显得尤为重要。

d) 动态扩展能力

动态扩展能力是适应不同场景的需要，是系统能否适用组织内部不同数据形态、不同分类分级需求的基础（如果不具备动态扩展的能力且但满足需求，则可初步认定该系统是项目级，非产品级）。动态扩展能力应包括敏感数据发现规则的动态拓展、元数据管理的动态扩展、标准自定义的动态扩展等。

e) 上下游系统结合能力

数据分类分级应具有上下游系统结合的能力（即需要丰富的接口）。应能提供上游态势可视化展示（数据分布可视化、数据流程可视化等）、资产应用等，下游的数据安全管控（审计、防火墙、脱敏、加密、数据防泄漏）等。

7. 隐私度量检测

7.1 概述

隐私度量指通过度量指标或度量方法揭示保护方法中存在的隐私信息泄露风险，侧面反映出隐私保护方法的隐私保护强度。不同的隐私保护技术在不同的隐私需求下处理数据的方式和性能不同。

根据隐私度量方法不同的特点，可综合采用基于匿名的隐私度量方法、基于信息熵的隐私度量方法、基于集对分析理论的隐私度量方法和基于差分隐私的隐私度量方法。针对大搜索平台的知识综合和智慧解答的特点，在隐私要素和搜索要素提取的基础上，结合上述隐私度量方法，建立用户隐私模型以及隐私信息传播模型，实现隐私信息的精准建模、动态度量以及隐私信息流向、搜索结果可管可控。

大搜索平台上的智能搜索服务在对用户的查询进行响应时，需要对用户身份进行隐私分级，严格访问控制机制，同时在传输过程中要利用加密、泛化等手段，以保证数据的隐私不泄露。大搜索隐私度量与管控模型如图 2 所示。

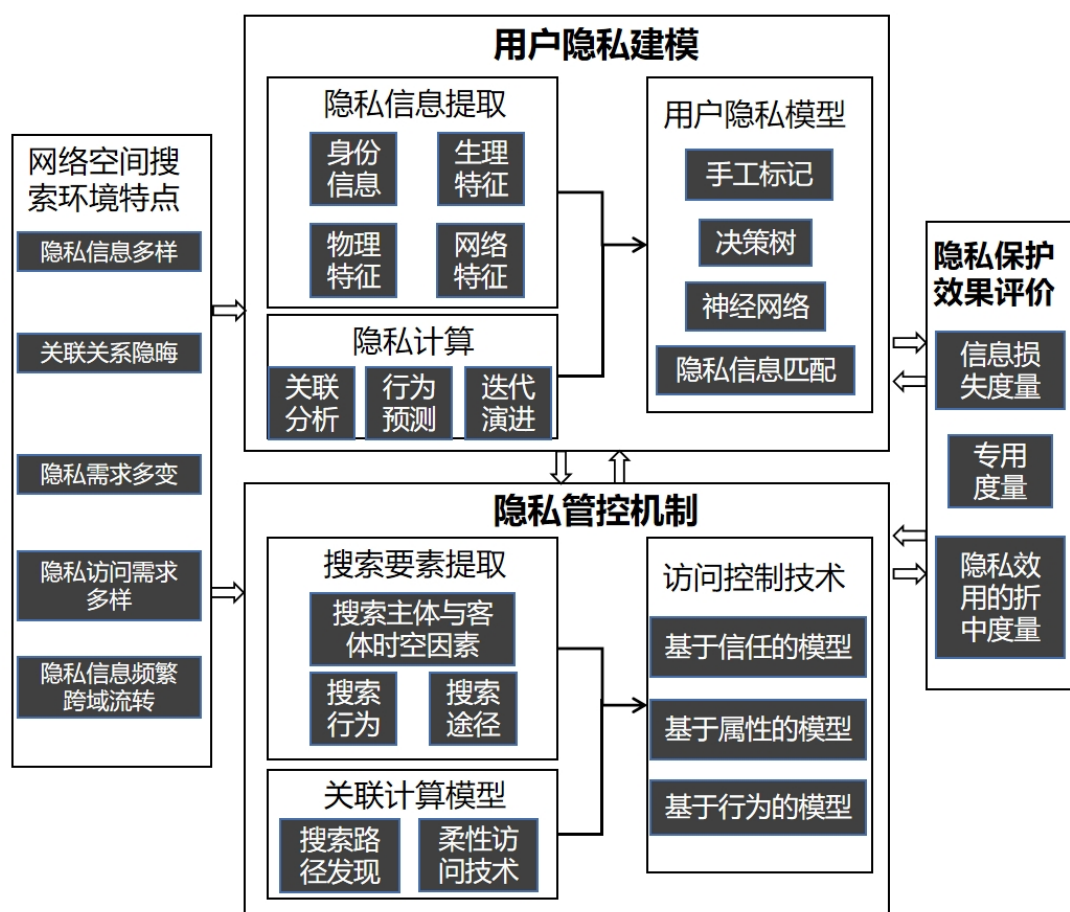


图 2 大搜索隐私度量检测

7.2 用户隐私建模

针对网络大空间搜索环境下隐私信息多样、关联关系隐晦、隐私需求多变等特点，应综合隐私信息关键要素提取、隐私计算进行用户隐私建模。

- a) 隐私信息关键要素应包括用户的身份信息、物理特征、生理特征、网络特征等关键要素。
- b) 隐私计算建议采用关联分析、行为预测及迭代演进的方法。
- c) 用户隐私建模应采用手工标记、决策树、神经网络、隐私信息匹配等技术，建立多维用户隐私模型。

7.3 隐私管控机制

针对隐私访问需求多样、隐私信息频繁跨域流转等特点，应在搜索要素抽取基础上，构建关联计算模型，实现隐私信息可管可控。

- a) 搜索要素抽取应综合考虑搜索主体与客体的时空因素、搜索途径、搜索行为等因素，在用户进行查询时，可以快速确定是否符合查询级别，能够判断是否能将结果提供给查询者，在需要时进行阻断。
- b) 可采用搜索路径发现、柔性访问控制等技术，构建查询用户与用户隐私之间的关联计算模型，实现对隐私信息流向、搜索结果跨系统传播的可管可控。
- c) 应保证信息访问的合法性、安全性以及可控性。在考虑环境和时态等多种因素的基础上，使用访问控制技术，向细粒度、多安全等级、跨域的方向延伸发展，授权依据开始逐渐面向主、客体的安全属性，采用基于信任、基于属性和基于行为等一系列基于安全属性的新型访问控制模型及其管理模型。
- d) 基于属性的访问控制应将各类属性包括用户属性、资源属性、环境属性等组合起来用于用户访问权限的设定。

7.4 隐私保护效果评价

应从以下几个方面评价发布数据的隐私保护效果：

a) 信息损失度量

信息损失度量宜采用InforLoss度量、最小扰动度量以及可辨识度度量等度量方法。

b) 专用度量

如果在进行数据发布前已经明确数据使用的目的，再对数据进行匿名化的操作的同时就需要考虑数据的应用需求，这样才能保留更多的有用信息。

c) 隐私效用的折中度量

应寻求一种确定的折中度量，隐私保护数据发布过程中既要保证用户隐私信息尽可能不被泄露，同时也要尽可能保证较高的发布数据的可用性。

8. 数据传输过程的隐私保护

8.1 用户查询中的隐私保护

在用户使用大搜索智能系统服务的过程中，用户发送的查询信息，包括文字、语音、图片等各种输入数据，应采用加密的传输协议，保证查询过程中用户的个人隐私不被泄露。

8.2 数据响应中的隐私保护

在用户执行搜索请求后，大搜索平台通过智能匹配、推理，通过隐私管控机制，向用户传输查询结果时，应采用加密的传输协议，保证在可控的范围内传播，保证数据和用户的隐私不被泄露。